An insurance company hoping to institute zero trust using static authorization faces several problems. Employees should only have access to the data and services they need to do their jobs. With near superhuman effort and lots of bespoke programming, the company's IT staff may be able to reduce the scope of employee access. They might have to settle for ensuring employees are logging in from a managed device by checking device status at the firewall, since retrofitting every system would be expensive. Protecting access to things like high-risk claims with just-in-time permissions escalation will require custom programming on only a few high-risk systems.

In short, trying to increase an organization's security posture using only static authorization tools will be time-consuming, expensive, and still fall short.

1.2.7 Consistency and transparency

Access control is usually governed by the business side of an organization since things like product features, regulatory compliance, and employee roles are business decisions. Governance decisions are communicated to the technical staff, who add their own access control decisions on things like IT security. Then these decisions are translated into static lists and embedded in applications or databases. This leads to situations where the business leaders charged with making policy have very little visibility into whether their policy choices are being implemented correctly. On top of that, because of the way static authorization is implemented and maintained, it's difficult to know if policy is being consistently applied.

Without a central view of policies, it's hard for business leaders to know who has access to what and harder still for technical staff to answer the question. Consider a multi-national retail company that operates in several regions. A customer support agent in the United States might accidentally be able to access customer payment details for a German customer, violating GDPR data residency rules. There's no easy way to detect this problem because the rules are not explicit and figuring out how to fix it could be costly. This lack of consistency is frustrating for employees and customers since no one understands why the system allows access for one agent but not another.